

Tool: API Contract (OpenAPI-style)

Apa: kontrak satu endpoint — request, response, error code, auth, idempotency, audit. Format manusia-baca tapi sejalan OpenAPI. **Kapan dipake:** tiap endpoint baru / ubah kontrak (SOP-SA-01), **disepakati @killua sebelum koding.** **Kenapa:** kontrak = Type-1. Lock di depan → no FE-BE integration bug krn beda ekspektasi (kontrol SA-C1). Transparency (TARIF) + audit trail (BAI03). **Output:** simpen di `tools/` / doc project (living, versi di-track).

TEMPLATE (copy mulai sini)

```
# API: <Method> <Path>

**Owner:** Saitama · **Status:** Draft / Locked / Implemented / Deprecated
**Auth:** public / required (role: X / scope: Y) · **Consumer:** @killua (FE)

## Purpose
<l baris business need>

## Request
### Headers
| Header | Required | Description |
|---|---|---|
| Authorization | yes (kalau auth) | Bearer <token> |
| Idempotency-Key | yes (kalau mutation sensitif) | UUID dari client |

### Path / Query / Body
| Param | In | Type | Required | Constraint |
|---|---|---|---|---|

```json
{ "field": "type – description – constraint" }
```

## Response — success `2xx`

```
{ "field": "type – description" }
```

## Error

Status	Code	Meaning	Body
400	VALIDATION_ERROR	input syntactic salah	<code>{ "error": "...", "details": [...] }</code>
401	UNAUTHENTICATED	token absen/invalid	...
403	FORBIDDEN	role/owner salah	...
409	CONFLICT	duplikat / idempotency	...
422	SEMANTIC_ERROR	valid syntactic, salah semantik	...

*Kode error harus sinkron dengan `error-code-table.md`.*

## Idempotency

- Yes (header `Idempotency-Key`, server dedup) / No (read-only)

## Rate limit

- N req / menit / user

## Audit trail (Data SACRED)

- Logged action: `<action_name>` · soft delete? `deleted_at` · audit col: `created_by` / `version`

## Example

```
```bash curl -X POST .../api/path -H "Authorization: Bearer ..." -d '{...}' ```
```

```
---

## CONTOH TERISI (dari proyek contoh – endpoint payment, uang = sensitif)

```markdown
API: POST /api/orders/{id}/payments

Owner: Saitama · **Status:** Locked · **Date:** 2026-05-29
Auth: required (role: user terverifikasi) · **Consumer:** @killua (form checkout)

Purpose
User bayar order (uang) ke merchant. Uang = sensitif → idempotent + audit STRICT.

Request
```

```

Headers
| Header | Required | Description |
|---|---|---|
| Authorization | yes | Bearer <token user> |
| Idempotency-Key | yes | UUID dari client (anti double-submit / double-charge) |

Path
| Param | In | Type | Required | Constraint |
|---|---|---|---|---|
| id | path | uuid | yes | order aktif (deleted_at IS NULL) |

Body
```json
{
  "amount": "int – nominal pembayaran (rupiah) – > 0, <= 10_000_000",
  "note": "string – catatan – max 280 char, optional",
  "payment_method": "enum – 'qris' | 'va' – required"
}

```

Response — success 201

```

{
  "payment_id": "uuid",
  "status": "PENDING – tunggu konfirmasi payment gateway",
  "amount": 150000,
  "created_at": "2026-05-29T10:00:00Z"
}

```

Error

Status	Code	Meaning	Body
400	VALIDATION_ERROR	amount <= 0 / method invalid	{ "error": "...", "details": [...] }
401	UNAUTHENTICATED	token absen/expired	{ "error": "login dulu" }
403	FORBIDDEN	user belum terverifikasi	{ "error": "verifikasi dulu" }
404	NOT_FOUND	order gak ada / soft-deleted	{ "error": "order gak ditemukan" }
409	CONFLICT	Idempotency-Key sama udah diproses	{ "payment_id": "<existing>" } (return yang lama, BUKAN buat baru)
422	LIMIT_EXCEEDED	amount > 10jt	{ "error": "nominal melebihi batas" }

Idempotency

- Yes — **Idempotency-Key**. Replay key sama → return payment lama (409 body payment existing), **gak double-charge** (kontrol SA-C6).

Rate limit

- 10 req / menit / user (anti-abuse + anti double-tap)

Audit trail (Data SACRED)

- Logged action: `payment.created` (siapa, kapan, amount, idempotency-key)
- Status uang **append-only event log** (`payment_event` : PENDING→PAID→SETTLED), **never overwrite status** — tiap transisi 1 entry
- Auto-settle EXPLICIT: pas webhook payment masuk → log `payment.settled` + notif merchant (gak silent)

Example

```
``bash curl -X POST ../api/orders/abc-123/payments \-H "Authorization: Bearer ..." -H  
"Idempotency-Key: 7f3e..." \-d '{"amount":150000,"payment_method":"qris","note":"Terima kasih!"}'  
... ``
```

*Kenapa kontrak ini Locked & Type-1: uang nempel di FE form + skema event log + isolasi saldo.
Ganti kontrak = breaking + migrasi data finansial → escalate via @kakashi ke Tata. Joint skema
`payment_event` sama @shikamaru.*